

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC HÙNG VƯƠNG TP.HCM



KHOA KỸ THUẬT CÔNG NGHỆ

HỌC PHẦN

LẬP TRÌNH WEB

ĐỒ ÁN NHÓM CUỐI KỲ

XÂY DỰNG WEBSITE BÁN QUẦN ÁO – GIÀY DÉP

THÀNH VIÊN :

TRẦN TUẤN ANH (TRƯỞNG NHÓM)

TRẦN TRUNG NGUYỄN

HỒ HUY HOÀNG

NGUYỄN HOÀNG ANH KHOA

LỚP:CT07PM

GVHD: LÊ DUY TÂN

Thành phố Hồ Chí Minh – 2026

MỤC LỤC

CHƯƠNG 1. GIỚI THIỆU ĐỀ TÀI.....	5
1.1. Lý do chọn đề tài.....	5
1.2. Mục tiêu của website.....	5
1.3. Đối tượng sử dụng.....	6
1.4. Phạm vi và giới hạn.....	6
CHƯƠNG 2. PHÂN TÍCH YÊU CẦU.....	7
2.1. Khảo sát hiện trạng.....	7
2.2. Yêu cầu chức năng.....	7
2.2.1. Nhóm chức năng phía khách hàng.....	7
2.2.2. Nhóm chức năng phía quản trị.....	8
2.3. Danh sách các tính năng chính.....	8
2.4. Yêu cầu phi chức năng.....	9
CHƯƠNG 3. THIẾT KẾ HỆ THỐNG.....	10
3.1. Công nghệ sử dụng.....	10
3.2. Kiến trúc tổng quan và mô hình MVC.....	11
3.3. Biểu đồ Use-case tổng quát.....	12
3.4. Luồng xử lý một request.....	13
3.5. Danh sách Servlet và ánh xạ URL.....	13
3.6. Tổ chức package mã nguồn.....	14
CHƯƠNG 4. THIẾT KẾ CƠ SỞ DỮ LIỆU.....	15
4.1. Tổng quan.....	15
4.2. Sơ đồ quan hệ thực thể (ERD).....	15
4.3. Chi tiết các bảng.....	16
4.3.1. Bảng <i>products</i> (sản phẩm).....	16
4.3.2. Bảng <i>product_variants</i> (phân loại).....	16

4.3.3. Bảng users (tài khoản)	17
4.3.4. Bảng orders (đơn hàng)	17
4.3.5. Bảng order_items (chi tiết đơn)	18
4.3.6. Bảng coupons (mã giảm giá)	18
4.4. Dữ liệu mẫu	18
CHƯƠNG 5. THIẾT KẾ GIAO DIỆN	20
5.1. Trang chủ	20
5.2. Chi tiết sản phẩm	21
5.3. Giỏ hàng	22
5.4. Đặt hàng (Checkout)	23
5.5. Đăng nhập & Dashboard quản trị	24
5.6. Quản lý sản phẩm (Admin)	25
5.7. Quản lý đơn hàng (Admin)	26
CHƯƠNG 6. CÀI ĐẶT CHỨC NĂNG	28
6.1. Trang chủ: duyệt, lọc, tìm kiếm, phân trang	28
6.2. Chi tiết sản phẩm: gallery, phân loại, đánh giá	28
6.3. Giỏ hàng lưu bằng Cookie	28
6.4. Thêm giỏ bằng AJAX và badge số lượng	29
6.5. Đặt hàng (Checkout): validate, coupon, phí ship	29
6.6. Xử lý đơn hàng bằng Transaction	29
6.7. Vòng đời & trạng thái đơn hàng	30
6.8. Hệ thống tài khoản khách hàng	31
6.9. Quản lý sản phẩm & upload ảnh (Admin)	31
6.10. Thống kê (Dashboard) & xuất Excel	31
6.11. Nhật ký hoạt động (Audit Log)	32
6.12. Bảo mật hệ thống	32

6.12.1. Chống SQL Injection	32
6.12.2. Mã hóa mật khẩu & chống dò mật khẩu	32
6.12.3. Phân quyền theo vai trò (Filter)	33
6.12.4. Các biện pháp bổ sung	33
6.13. Kiểm thử	33
CHƯƠNG 7. PHÂN CÔNG CÔNG VIỆC NHÓM	35
7.1. Mức độ đóng góp	35
7.2. Quy trình Git	35
7.3. Thống kê mã nguồn	36
CHƯƠNG 8. KẾT QUẢ ĐẠT ĐƯỢC	37
8.1. Các chức năng đã hoàn thành	37
8.2. Những điểm nổi bật của sản phẩm	37
8.3. Những hạn chế còn tồn tại	37
CHƯƠNG 9. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	38
9.1. Kết luận	38
9.2. Hướng phát triển	38
CHƯƠNG 10. TÀI LIỆU THAM KHẢO	39
CHƯƠNG Phụ lục. HƯỚNG DẪN CÀI ĐẶT VÀ CHẠY	40

CHƯƠNG 1. GIỚI THIỆU ĐỀ TÀI

1.1. Lý do chọn đề tài

Thương mại điện tử (e-commerce) đã trở thành kênh mua sắm chủ đạo tại Việt Nam, đặc biệt trong lĩnh vực thời trang – quần áo và giày dép. Người tiêu dùng ngày càng ưu tiên việc xem sản phẩm, so sánh giá và đặt hàng trực tuyến thay vì phải đến cửa hàng. Đối với các cửa hàng thời trang vừa và nhỏ, một website bán hàng gọn nhẹ, dễ vận hành là giải pháp phù hợp để mở rộng kênh bán.

Xuất phát từ nhu cầu đó, nhóm chọn đề tài “Xây dựng website bán quần áo – giày dép” làm đồ án môn Lập trình Web. Đề tài vừa mang tính thực tiễn cao, vừa bao phủ trọn vẹn các kiến thức cốt lõi của môn học: HTML/CSS/JavaScript, JSP, Servlet, JDBC và cơ sở dữ liệu, tổ chức theo mô hình MVC.

1.2. Mục tiêu của website

Xây dựng một ứng dụng web thương mại điện tử hoàn chỉnh gồm hai phân hệ, chạy được end-to-end:

- **Phân hệ khách hàng (Front-end store):** xem danh sách, lọc – tìm kiếm – sắp xếp sản phẩm; xem chi tiết kèm thư viện ảnh và phân loại (size/màu); thêm giỏ hàng; đặt hàng; đăng ký/đăng nhập tài khoản, xem lịch sử đơn, yêu thích và đánh giá.
- **Phân hệ quản trị (Admin):** đăng nhập bảo mật; quản lý sản phẩm – danh mục – đơn hàng – mã giảm giá – người dùng; thống kê doanh thu bằng biểu đồ; xuất báo cáo Excel; ghi nhật ký thao tác (audit log).

Về mặt kỹ thuật, đề tài hướng tới việc áp dụng đúng mô hình MVC, đảm bảo an toàn dữ liệu (PreparedStatement chống SQL Injection, mã hóa mật khẩu BCrypt), và xử lý các nghiệp vụ có tính toàn vẹn cao như trừ tồn kho trong giao dịch (transaction).

1.3. Đối tượng sử dụng

Đối tượng (Actor)	Mô tả & quyền hạn
Khách vãng lai	Duyệt/lọc/tìm sản phẩm, xem chi tiết, thêm giỏ hàng (Cookie), đặt hàng bằng SĐT.
Khách có tài khoản (CUSTOMER)	Toàn bộ quyền khách vãng lai, thêm: đăng ký/đăng nhập, xem lịch sử đơn, cập nhật hồ sơ, yêu thích, đánh giá sản phẩm đã mua.
Nhân viên (STAFF)	Đăng nhập khu quản trị nhưng CHỈ được xem/xử lý đơn hàng, xem dashboard, đổi mật khẩu.
Quản trị viên (ADMIN)	Toàn quyền: quản lý sản phẩm, danh mục, đơn hàng, mã giảm giá, người dùng và xem nhật ký hoạt động.

1.4. Phạm vi và giới hạn

Nội dung	Phạm vi thực hiện
Mô hình bán hàng	Đặt hàng không thanh toán online. Khách gửi đơn kèm SĐT → admin gọi điện xác nhận và giao hàng (mô hình COD/liên hệ).
Nền tảng	Ứng dụng web chạy trên trình duyệt, giao diện responsive nhờ Bootstrap 5.
Không bao gồm	Cổng thanh toán trực tuyến, ví điện tử, tích hợp vận chuyển bên thứ ba, gợi ý bằng AI.

CHƯƠNG 2. PHÂN TÍCH YÊU CẦU

2.1. Khảo sát hiện trạng

Nhóm tham khảo các sàn/website bán thời trang phổ biến (Shopee, các shop giày trên nền tảng riêng) và rút ra những đặc điểm chung mà một website bán quần áo – giày dép cần có: danh mục sản phẩm rõ ràng, bộ lọc theo giá và danh mục, ô tìm kiếm gợi ý nhanh, trang chi tiết nhiều ảnh và tùy chọn size, giỏ hàng tiện lợi, luồng đặt hàng đơn giản. Về phía quản trị, cửa hàng cần công cụ quản lý tồn kho, theo dõi đơn theo trạng thái và xem báo cáo doanh thu. Từ khảo sát, nhóm xác định phạm vi hợp lý cho một đồ án môn học: giữ trọn các nghiệp vụ cốt lõi của một cửa hàng thời trang thực tế nhưng lược bỏ thanh toán online để tập trung vào kỹ thuật lập trình web.

2.2. Yêu cầu chức năng

2.2.1. Nhóm chức năng phía khách hàng

Mã	Chức năng	Mô tả
FE-01	Duyệt & lọc sản phẩm	Danh sách sản phẩm phân trang (6 SP/trang); lọc theo danh mục, khoảng giá; sắp xếp theo giá/mới nhất/bán chạy.
FE-02	Tìm kiếm gợi ý (Autocomplete)	Gõ từ khóa ≥ 2 ký tự trả về tối đa 5 gợi ý qua AJAX/JSON.
FE-03	Chi tiết sản phẩm	Thư viện nhiều ảnh (gallery), phân loại size/màu với giá & tồn kho riêng, sản phẩm liên quan.
FE-04	Xem nhanh (Quick-view)	Modal xem nhanh thông tin sản phẩm ngay trên trang chủ, không rời trang.
FE-05	Giỏ hàng (Cookie)	Thêm/sửa số lượng/đổi size/xóa; lưu bằng Cookie 7 ngày; kiểm tra tồn kho phía server.
FE-06	Thêm giỏ bằng AJAX	Thêm sản phẩm không tải lại trang, cập nhật badge số lượng, hiển thị thông báo Toast.
FE-07	Đặt hàng (Checkout)	Nhập tên/SĐT/địa chỉ, áp mã giảm giá, tính phí ship (freeship từ 500.000đ), tạo đơn.
FE-08	Tài khoản khách hàng	Đăng ký, đăng nhập, ghi nhớ đăng nhập, xem/sửa hồ sơ, xem lịch sử đơn hàng.
FE-09	Yêu thích (Wishlist)	Thêm/bỏ sản phẩm yêu thích (yêu cầu đăng nhập), đếm số lượng qua AJAX.
FE-10	Đánh giá sản phẩm	Khách đã mua (xác thực qua SĐT) được chấm 1–5 sao và bình luận.

2.2.2. Nhóm chức năng phía quản trị

Mã	Chức năng	Mô tả
BE-01	Đăng nhập bảo mật	Xác thực BCrypt, khóa tài khoản tạm thời khi sai 5 lần, ghi nhớ đăng nhập.
BE-02	Quản lý sản phẩm (CRUD)	Thêm/xem/sửa/xóa, upload ảnh, quản lý phân loại & giảm giá, tìm kiếm theo tên, validate phía server.
BE-03	Quản lý danh mục (CRUD)	Thêm/xem/sửa/xóa danh mục sản phẩm.
BE-04	Quản lý đơn hàng	Danh sách có lọc + phân trang; xem chi tiết; đổi trạng thái theo luật; ghi chú nội bộ.
BE-05	Quản lý mã giảm giá (CRUD)	Tạo/sửa/xóa coupon: % giảm, số lượt tối đa, hạn dùng, bật/tắt.
BE-06	Quản lý người dùng	Xem danh sách tài khoản, khóa/mở tài khoản, phân vai trò.
BE-07	Thống kê (Dashboard)	Tổng doanh thu, số đơn, biểu đồ (Chart.js), top bán chạy, cảnh báo sắp hết hàng, xuất báo cáo Excel.
BE-08	Nhật ký hoạt động	Ghi lại thao tác Thêm/Sửa/Xóa của admin (ai, làm gì, khi nào).

2.3. Danh sách các tính năng chính

Website đáp ứng vượt yêu cầu tối thiểu “ít nhất 4 tính năng chính” và có đầy đủ CRUD trên nhiều đối tượng:

#	Tính năng chính	CRUD / Nghiệp vụ
1	Quản lý sản phẩm	Create · Read · Update · Delete + upload ảnh, phân loại, tìm kiếm
2	Quản lý danh mục	Create · Read · Update · Delete
3	Giỏ hàng & Đặt hàng	Giỏ Cookie + AJAX; đặt hàng trong transaction (trừ tồn kho, coupon, phí ship)
4	Tìm kiếm & Lọc sản phẩm	Lọc danh mục/giá, sắp xếp, gợi ý autocomplete, phân trang
5	Tài khoản & Phân quyền	Đăng ký/đăng nhập, 3 vai trò ADMIN/STAFF/CUSTOMER, BCrypt, khóa tài khoản
6	Thống kê & Báo cáo	Dashboard biểu đồ, xuất Excel, nhật ký hoạt động

2.4. Yêu cầu phi chức năng

Tiêu chí	Yêu cầu
Bảo mật	Chống SQL Injection (PreparedStatement), mã hóa mật khẩu (BCrypt), phân quyền theo vai trò, chống brute-force, chống XSS ở dữ liệu nhúng vào JavaScript.
Toàn vẹn dữ liệu	Trừ tiền kho & trừ lượt coupon trong giao dịch (transaction) có commit/rollback.
Hiệu năng	Có chỉ mục (index) trên các cột lọc; phân trang danh sách; truy vấn tham số hóa.
Khả dụng / UX	Giao diện responsive (Bootstrap 5), thông báo lỗi rõ ràng, badge giỏ hàng, Toast, trang lỗi tùy chỉnh 404/500/403.
Khả chuyển	Chạy được không cần cài Tomcat thủ công nhờ plugin Cargo tự tải Tomcat 9.
Bảo trì	Tách lớp rõ ràng theo MVC (Model – DAO – Controller – View), mã nguồn có chú thích tiếng Việt.

CHƯƠNG 3. THIẾT KẾ HỆ THỐNG

3.1. Công nghệ sử dụng

Thành phần	Công nghệ / Phiên bản	Vai trò trong dự án
Ngôn ngữ	Java 11	Ngôn ngữ lập trình phía máy chủ.
Web layer	Java Servlet API 4.0.1	Nhận request, điều phối, trả response (lớp Controller).
View	JSP + JSTL 1.2	Sinh HTML động, dùng vòng lặp/điều kiện trong trang.
Cơ sở dữ liệu	MySQL 8 (Connector/J 8.0.33)	Lưu trữ dữ liệu quan hệ, truy xuất qua JDBC.
Bảo mật mật khẩu	BCrypt 0.4	Băm & kiểm tra mật khẩu theo thuật toán BCrypt.
Giao diện	Bootstrap 5 (CDN)	Khung CSS responsive, thành phần giao diện.
Biểu đồ	Chart.js (CDN)	Vẽ biểu đồ doanh thu trên dashboard.
Xuất báo cáo	Apache POI 5.2.3	Xuất báo cáo doanh thu ra file Excel (.xlsx).
Build tool	Apache Maven (gói WAR)	Quản lý thư viện, đóng gói ứng dụng.
Web server	Apache Tomcat 9.0.89	Servlet container chạy ứng dụng.
Chạy nhanh	Cargo Maven Plugin 1.10.14	Tự tải Tomcat 9 và chạy app không cần cài đặt thủ công (cổng 8081).

Servlet đảm nhiệm vai trò Controller: tiếp nhận HTTP request, gọi tầng nghiệp vụ (DAO) và forward sang JSP để hiển thị. Hầu hết Servlet khai báo đường dẫn bằng annotation `@WebServlet` nên không cần cấu hình thủ công trong `web.xml`. JSP kết hợp thẻ JSTL (core, format) để lặp danh sách, định dạng tiền tệ và điều kiện hiển thị. Dữ liệu lưu trong MySQL bằng mã `utf8mb4`; ứng dụng kết nối qua JDBC và dùng `PreparedStatement` tham số hóa. Lớp tiện ích `DBConnection` tập trung việc mở kết nối:

```

public class DBConnection {
    private static final String URL =
        "jdbc:mysql://localhost:3306/shop_db?useSSL=false"
        + "&serverTimezone=UTC&characterEncoding=UTF-8&allowPublicKeyRetrieval=true";
    private static final String USER = "root";
    private static final String PASSWORD = "root"; // đổi theo máy của bạn

    public static Connection getConnection() throws SQLException {
        try {
            Class.forName("com.mysql.cj.jdbc.Driver");
        } catch (ClassNotFoundException e) {
            throw new SQLException("Không tìm thấy MySQL Driver", e);
        }
        return DriverManager.getConnection(URL, USER, PASSWORD);
    }
}

```

Mã 3.1: Lớp DBConnection mở kết nối tới MySQL qua JDBC

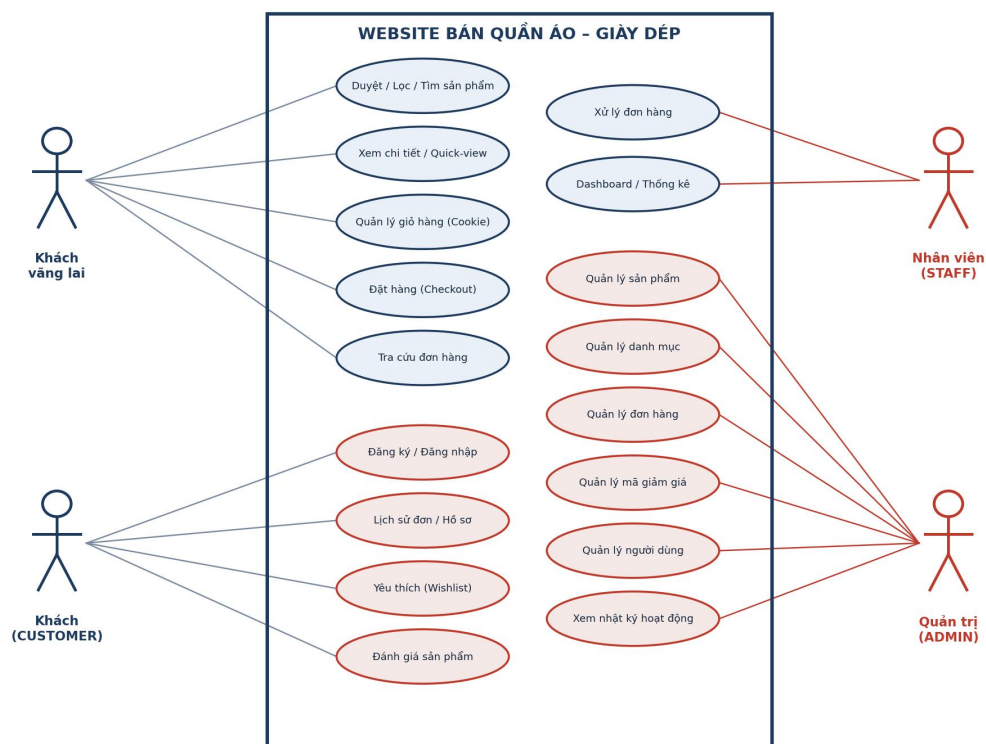
3.2. Kiến trúc tổng quan và mô hình MVC

Toàn bộ hệ thống được tổ chức theo mô hình MVC (Model – View – Controller), bổ sung thêm hai lớp phụ trợ là DAO (Data Access Object) và Filter. Cách tách lớp này giúp mã nguồn rõ ràng, dễ phân công cho 4 thành viên và dễ bảo trì.

Tầng	Vai trò	Ví dụ trong dự án
Model	Lớp dữ liệu thuần (getter/setter)	Product, Order, OrderItem, User, CartItem, Coupon, Review...
DAO	Giao tiếp với MySQL qua JDBC	ProductDAO.getAll(), OrderDAO.createOrder(), UserDAO.findByUsername()
Controller (Servlet)	Nhận request, gọi DAO, đẩy dữ liệu sang View	HomeServlet, CheckoutServlet, AdminProductServlet
View (JSP)	Hiển thị HTML + Bootstrap	home.jsp, product-detail.jsp, dashboard.jsp
Filter	Chặn/tiền xử lý request	AuthFilter (phân quyền), EncodingFilter, RememberMeFilter
Util	Tiện ích dùng chung	DBConnection, CartCookieHelper

3.3. Biểu đồ Use-case tổng quát

Hệ thống có bốn tác nhân chính. Sơ đồ use-case dưới đây tóm tắt các ca sử dụng theo từng tác nhân:

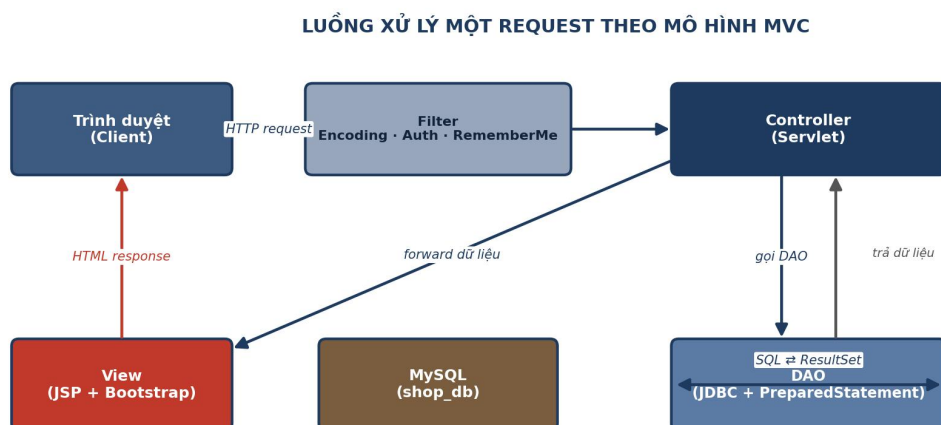


Ghi chú: CUSTOMER kế thừa mọi ca của Khách vắng lai · ADMIN có toàn quyền (bao gồm quyền của STAFF)

Hình 3.1: Sơ đồ Use-case tổng quát của hệ thống

3.4. Luồng xử lý một request

Sơ đồ dưới minh họa luồng xử lý điển hình khi khách truy cập một trang: request đi qua các Filter, tới Controller (Servlet), Controller gọi DAO để truy vấn MySQL, rồi chuyển dữ liệu sang View (JSP) để sinh HTML trả về trình duyệt.



Hình 3.2: Luồng xử lý một request theo mô hình MVC

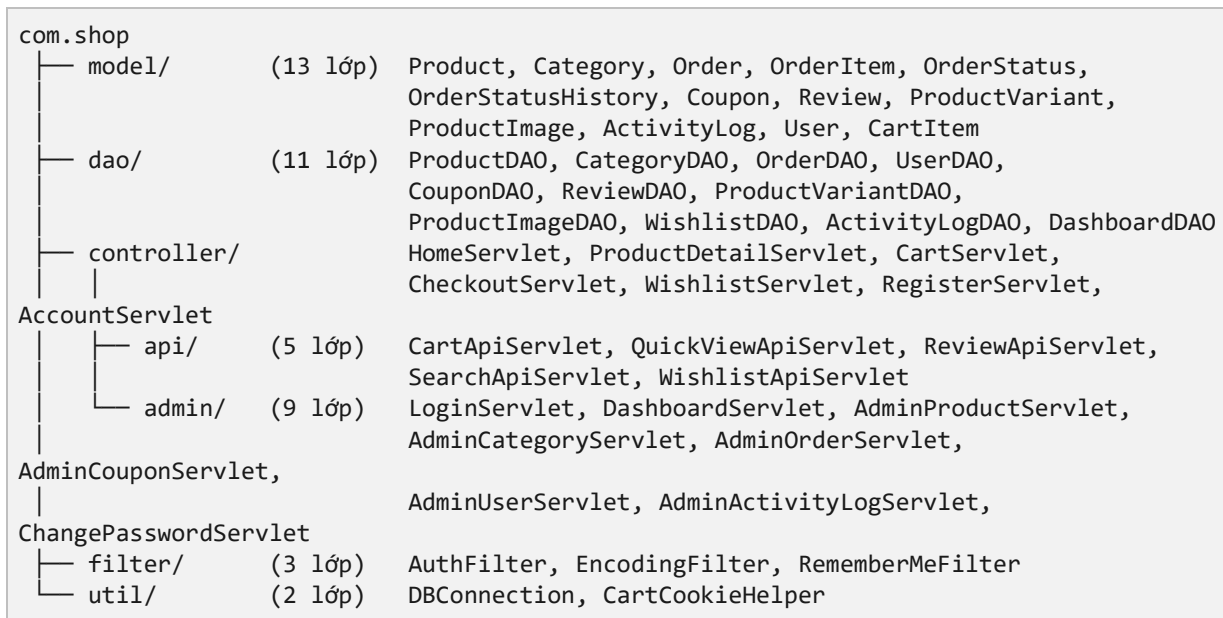
3.5. Danh sách Servlet và ánh xạ URL

Servlet	URL	Chức năng
HomeServlet	/ , /home	Trang chủ, lọc, tìm, phân trang
ProductDetailServlet	/product	Chi tiết SP, gallery, phân loại, liên quan
CartServlet	/cart	Giỏ hàng Cookie: add/update/updateSize/remove
CheckoutServlet	/checkout	Đặt hàng, coupon, phí ship, validate
RegisterServlet	/register	Đăng ký tài khoản khách
AccountServlet	/account	Hồ sơ + lịch sử đơn của khách
WishlistServlet	/wishlist	Trang danh sách yêu thích
CartApiServlet	/api/cart/add	Thêm giỏ hàng bằng AJAX (JSON)
SearchApiServlet	/api/search	Gợi ý tìm kiếm (JSON)
QuickViewApiServlet	/api/product/quickview	Dữ liệu xem nhanh (JSON)
ReviewApiServlet	/api/review	Gửi đánh giá (JSON)
WishlistApiServlet	/api/wishlist/toggle, /count	Bật/tắt & đếm yêu thích (JSON)

Servlet	URL	Chức năng
LoginServlet	/login, /logout, /admin/login, /admin/logout	Đăng nhập/đăng xuất
DashboardServlet	/admin/dashboard	Thống kê, biểu đồ, xuất Excel
AdminProductServlet	/admin/products	CRUD sản phẩm + upload ảnh
AdminCategoryServlet	/admin/categories	CRUD danh mục
AdminOrderServlet	/admin/orders	Quản lý & xử lý đơn hàng
AdminCouponServlet	/admin/coupons	Quản lý mã giảm giá
AdminUserServlet	/admin/users	Quản lý người dùng
AdminActivityLogServlet	/admin/logs	Xem nhật ký hoạt động
ChangePasswordServlet	/admin/change-password	Đổi mật khẩu

3.6. Tổ chức package mã nguồn

Mã nguồn Java được tổ chức trong package gốc com.shop, chia theo vai trò:



Hình 3.3: Sơ đồ tổ chức package mã nguồn (khoảng 50 lớp Java)

CHƯƠNG 4. THIẾT KẾ CƠ SỞ DỮ LIỆU

4.1. Tổng quan

Cơ sở dữ liệu shop_db gồm 12 bảng, bảng mã utf8mb4_unicode_ci. Thiết kế tách biệt: danh mục – sản phẩm – phân loại (variant) – ảnh; đơn hàng – chi tiết đơn – lịch sử trạng thái; người dùng; mã giảm giá; đánh giá; yêu thích; và nhật ký hoạt động. Đặc biệt, giỏ hàng KHÔNG có bảng riêng mà được lưu trong Cookie của trình duyệt, giúp khách chưa đăng nhập vẫn mua hàng được.

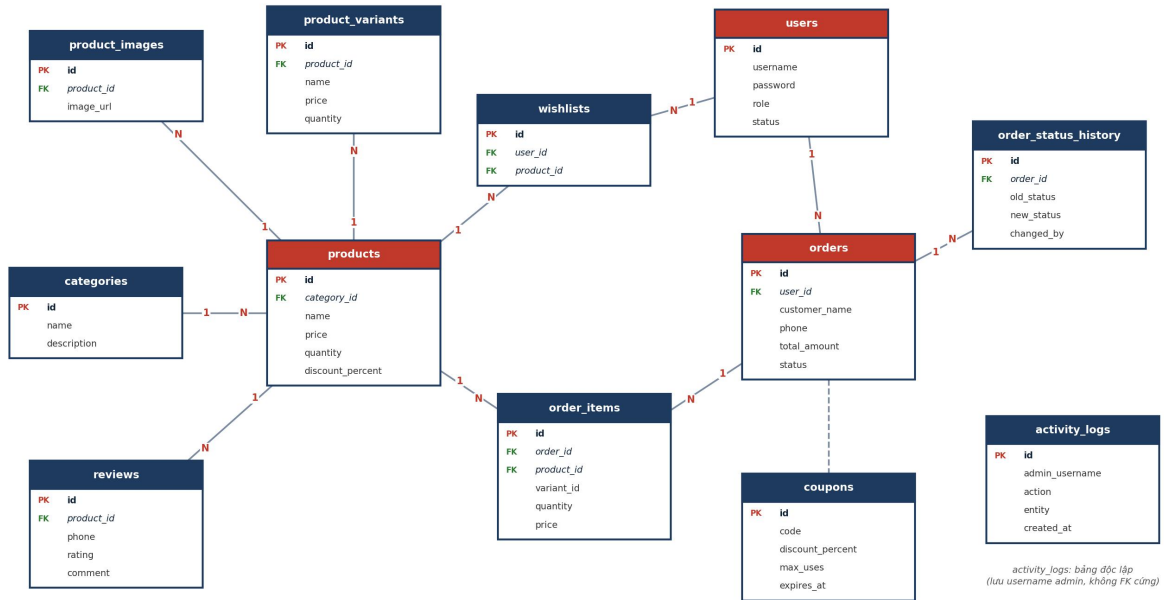
#	Bảng	Ý nghĩa
1	categories	Danh mục sản phẩm (8 danh mục mẫu)
2	products	Sản phẩm (giá, tồn kho, % giảm giá, ảnh chính)
3	product_variants	Phân loại theo size/màu, giá & tồn kho riêng
4	product_images	Ảnh phụ (thư viện gallery) của sản phẩm
5	users	Tài khoản (ADMIN / STAFF / CUSTOMER), khóa & remember token
6	orders	Đơn hàng (thông tin khách, tổng tiền, ship, coupon, trạng thái)
7	order_items	Chi tiết từng dòng của đơn (lưu giá tại thời điểm mua)
8	order_status_history	Lịch sử chuyển trạng thái đơn hàng
9	coupons	Mã giảm giá (% , số lượt, hạn dùng, bật/tắt)
10	reviews	Đánh giá sản phẩm (1–5 sao) của khách đã mua
11	wishlists	Sản phẩm yêu thích của người dùng
12	activity_logs	Nhật ký thao tác của quản trị viên

4.2. Sơ đồ quan hệ thực thể (ERD)

Sơ đồ ERD thể hiện các quan hệ khóa ngoại chính giữa 12 bảng:

SƠ ĐỒ QUAN HỆ THỰC THỂ (ERD) - shop_db (12 bảng)

PK: khóa chính · FK: khóa ngoại · 1 – N: quan hệ một-nhiều · -- -: liên kết mềm



Hình 4.1: Sơ đồ quan hệ thực thể (ERD) của cơ sở dữ liệu shop_db

4.3. Chi tiết các bảng

4.3.1. Bảng products (sản phẩm)

Cột	Kiểu dữ liệu	Ràng buộc / Ý nghĩa
id	INT AI	Khóa chính
category_id	INT	FK → categories(id)
name	VARCHAR(200)	Tên sản phẩm (NOT NULL)
description	TEXT	Mô tả chi tiết
price	DECIMAL(12,0)	Giá bán gốc (VND)
image	VARCHAR(255)	Tên file ảnh chính
quantity	INT	Tồn kho tổng
discount_percent	INT	% giảm giá (0–100)
created_at	DATETIME	Ngày tạo (mặc định NOW)

4.3.2. Bảng product_variants (phân loại)

Cột	Kiểu dữ liệu	Ràng buộc / Ý nghĩa
id	INT AI	Khóa chính
product_id	INT	FK → products(id), ON DELETE CASCADE

Cột	Kiểu dữ liệu	Ràng buộc / Ý nghĩa
name	VARCHAR(150)	Tên phân loại (vd 'Size 40', 'Đen - Size M')
price	DECIMAL(12,0)	Giá riêng của phân loại
quantity	INT	Tồn kho riêng của phân loại

4.3.3. Bảng users (tài khoản)

Cột	Kiểu dữ liệu	Ràng buộc / Ý nghĩa
id	INT AI	Khóa chính
username	VARCHAR(50)	Tên đăng nhập (UNIQUE)
password	VARCHAR(255)	Mật khẩu đã băm BCrypt
full_name	VARCHAR(150)	Họ tên
phone	VARCHAR(20)	SĐT (UNIQUE) – dùng liên kết đơn/đánh giá
address	VARCHAR(255)	Địa chỉ
role	VARCHAR(20)	ADMIN / STAFF / CUSTOMER (mặc định CUSTOMER)
status	VARCHAR(20)	ACTIVE / LOCKED
failed_attempts	INT	Số lần đăng nhập sai liên tiếp
lock_time	DATETIME	Thời điểm bị khóa tạm
remember_token	VARCHAR(255)	Token ghi nhớ đăng nhập

4.3.4. Bảng orders (đơn hàng)

Cột	Kiểu dữ liệu	Ràng buộc / Ý nghĩa
id	INT AI	Khóa chính
user_id	INT NULL	FK → users(id) nếu khách đã đăng nhập (ON DELETE SET NULL)
customer_name	VARCHAR(150)	Tên người nhận
phone	VARCHAR(20)	SĐT người nhận
address	VARCHAR(255)	Địa chỉ giao
note / admin_note	VARCHAR(500)	Ghi chú khách / ghi chú nội bộ admin
total_amount	DECIMAL(12,0)	Tổng cuối = tạm tính – giảm giá + ship
ship_fee	DECIMAL(12,0)	Phí vận chuyển (0 nếu freeship)
coupon_code	VARCHAR(50)	Mã giảm giá đã áp
discount_amount	DECIMAL(12,0)	Số tiền được giảm
status	VARCHAR(30)	PENDING / CONFIRMED / SHIPPING / DELIVERED / CANCELLED

Cột	Kiểu dữ liệu	Ràng buộc / Ý nghĩa
created_at	DATETIME	Ngày đặt

4.3.5. Bảng *order_items* (chi tiết đơn)

Cột	Kiểu dữ liệu	Ràng buộc / Ý nghĩa
id	INT AI	Khóa chính
order_id	INT	FK → orders(id)
product_id	INT	FK → products(id)
variant_id	INT NULL	Phân loại đã chọn (NULL nếu không có)
variant_name	VARCHAR(150)	Tên phân loại tại thời điểm mua
quantity	INT	Số lượng mua
price	DECIMAL(12,0)	Giá tại thời điểm mua (đã áp giảm giá)

4.3.6. Bảng *coupons* (mã giảm giá)

Cột	Kiểu dữ liệu	Ràng buộc / Ý nghĩa
id	INT AI	Khóa chính
code	VARCHAR(50)	Mã (UNIQUE), vd SALE10
discount_percent	INT	% giảm trên tạm tính
max_uses / used_count	INT	Số lượt tối đa / đã dùng
expires_at	DATETIME NULL	Hạn dùng (NULL = không hết hạn)
active	TINYINT(1)	Bật/tắt mã

Các bảng còn lại — *order_status_history* (lịch sử trạng thái), *reviews* (đánh giá 1–5 sao), *product_images* (ảnh phụ), *wishlists* (yêu thích, UNIQUE theo cặp user–product), và *activity_logs* (nhật ký admin: hành động, đối tượng, thời gian) — có cấu trúc tương tự với khóa ngoại tới bảng cha tương ứng.

4.4. Dữ liệu mẫu

Script `database/database.sql` khởi tạo sẵn dữ liệu để demo: 8 danh mục, 30 sản phẩm kèm khoảng 100 phân loại, 4 mã giảm giá (gồm mã còn hạn, mã sắp hết lượt, mã hết hạn, mã đã tắt để minh họa đủ trường hợp), 7 tài khoản (1 ADMIN, 1 STAFF, 5 CUSTOMER —

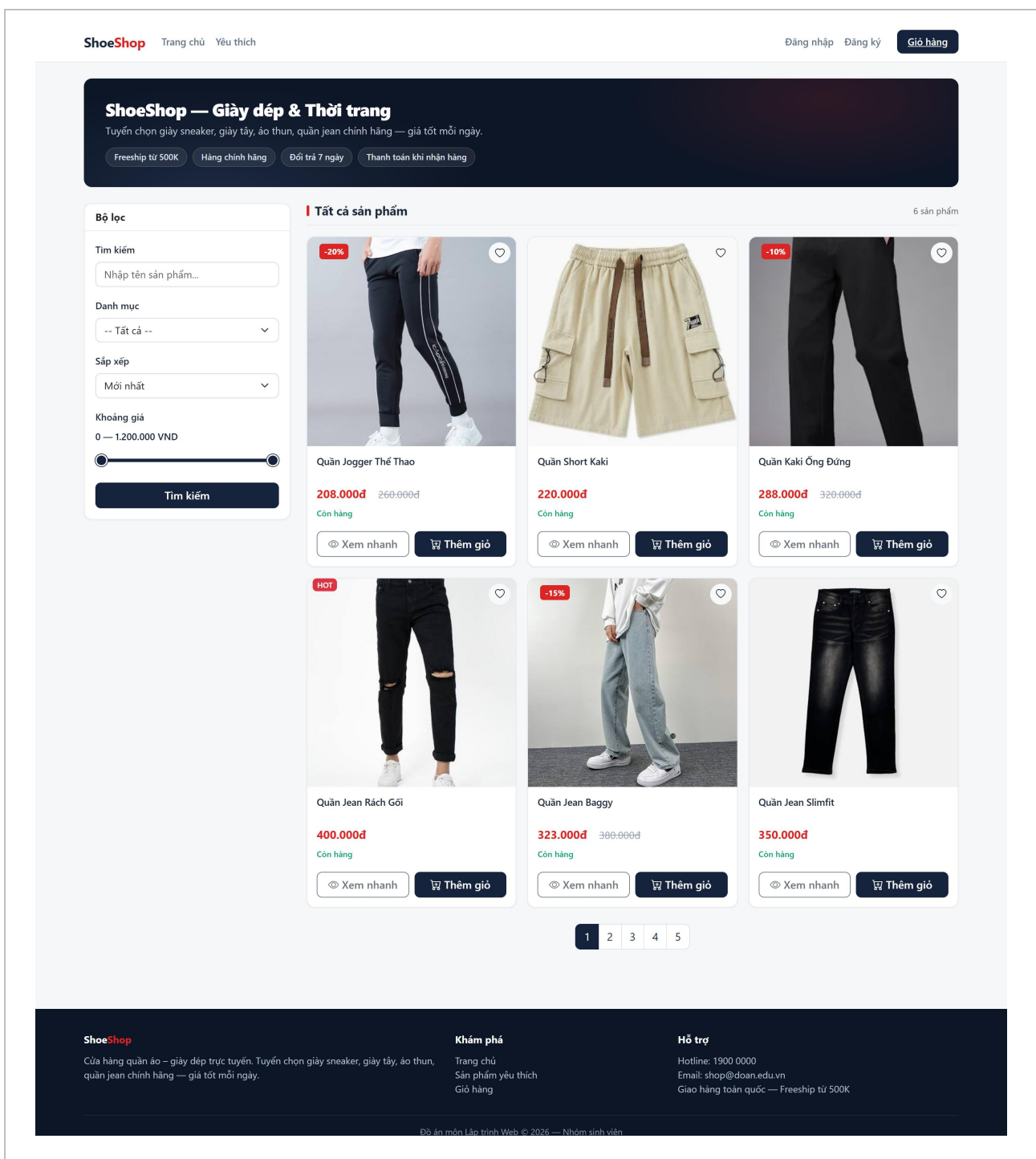
mật khẩu mặc định 123456), 21 đơn hàng trải đều nhiều trạng thái và mốc thời gian trong 6 tháng để biểu đồ thống kê có dữ liệu trực quan.

CHƯƠNG 5. THIẾT KẾ GIAO DIỆN

Giao diện được xây dựng bằng Bootstrap 5 đảm bảo responsive trên nhiều kích thước màn hình. Chương này giới thiệu các màn hình chính của website kèm mô tả chức năng từng màn hình. (Ảnh chụp từ hệ thống chạy thực tế tại <http://localhost:8081/shop>.)

5.1. Trang chủ

Trang chủ hiển thị lưới sản phẩm dạng card, thanh điều hướng có ô tìm kiếm gợi ý và badge giỏ hàng, bộ lọc theo danh mục và khoảng giá, tùy chọn sắp xếp và phân trang. Mỗi card có nút thêm giỏ nhanh và xem nhanh (quick-view).



Hình 5.1: Trang chủ với bộ lọc danh mục, thanh trượt giá và ô tìm kiếm gợi ý

5.2. Chi tiết sản phẩm

Trang chi tiết hiển thị thư viện nhiều ảnh, danh sách phân loại (size/màu) với giá và tồn kho riêng, phần trăm giảm giá, nút thêm giỏ / mua ngay, khu vực đánh giá 1–5 sao và các sản phẩm liên quan.

ShoeShop

[Trang chủ](#)
[Yêu thích](#)

[Đăng nhập](#)
[Đăng ký](#)

Giỏ hàng

[Trang chủ](#)
[Giày thể thao](#)
[Giày Sneaker Trắng](#)

Giày Sneaker Trắng

Giày thể thao | Còn hàng

337.500 – 360.000 đ

450.000 đ -25%

Phân loại

Size 39

Size 40

Size 41

Size 42

Số lượng

-

1

+

Thêm vào giỏ

Mua ngay

Yêu thích

✓ Giao hàng toàn quốc

✓ Đổi trả trong 7 ngày

✓ Cam kết hàng chính hãng

Mô tả sản phẩm

Giày sneaker màu trắng năng động.

Thông tin chi tiết

Mã sản phẩm	#1
Danh mục	Giày thể thao
Giá bán	450.000 đ
Tồn kho	50 sản phẩm

Đánh giá sản phẩm

Gửi đánh giá của bạn

Số điện thoại (đã dùng mua hàng)

09xxxxxxx

Mức độ hài lòng

★★★★★ (Tuyệt vời)

Bình luận của bạn

Chia sẻ trải nghiệm của bạn về sản phẩm...

Gửi đánh giá

Khách hàng đánh giá

Chưa có đánh giá nào.

Hãy là người đầu tiên nhận xét về sản phẩm này!

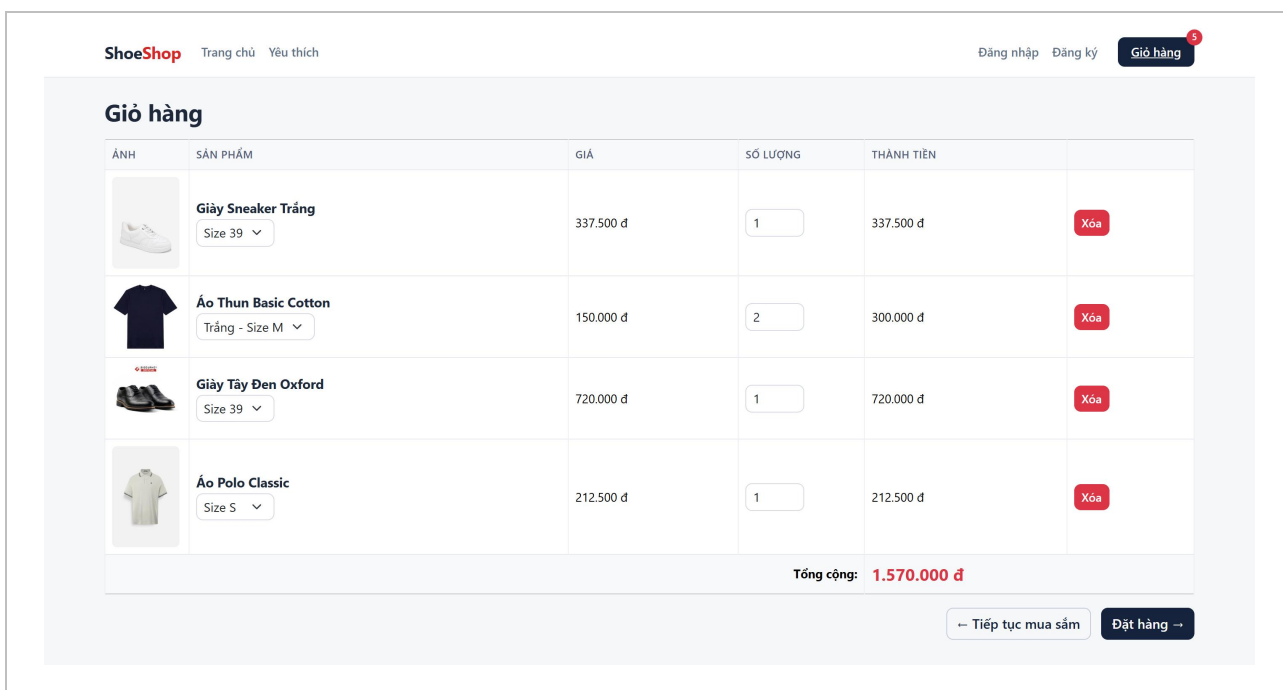
Sản phẩm liên quan

Hình 5.2: Trang chi tiết sản phẩm: gallery ảnh, chọn phân loại và đánh giá

5.3. Giỏ hàng

Trang giỏ hàng liệt kê các dòng sản phẩm đã chọn, cho phép cập nhật số lượng, đổi size, xóa dòng và tự động tính lại tạm tính. Giỏ hàng được lưu trong Cookie nên khách chưa đăng nhập vẫn dùng được.

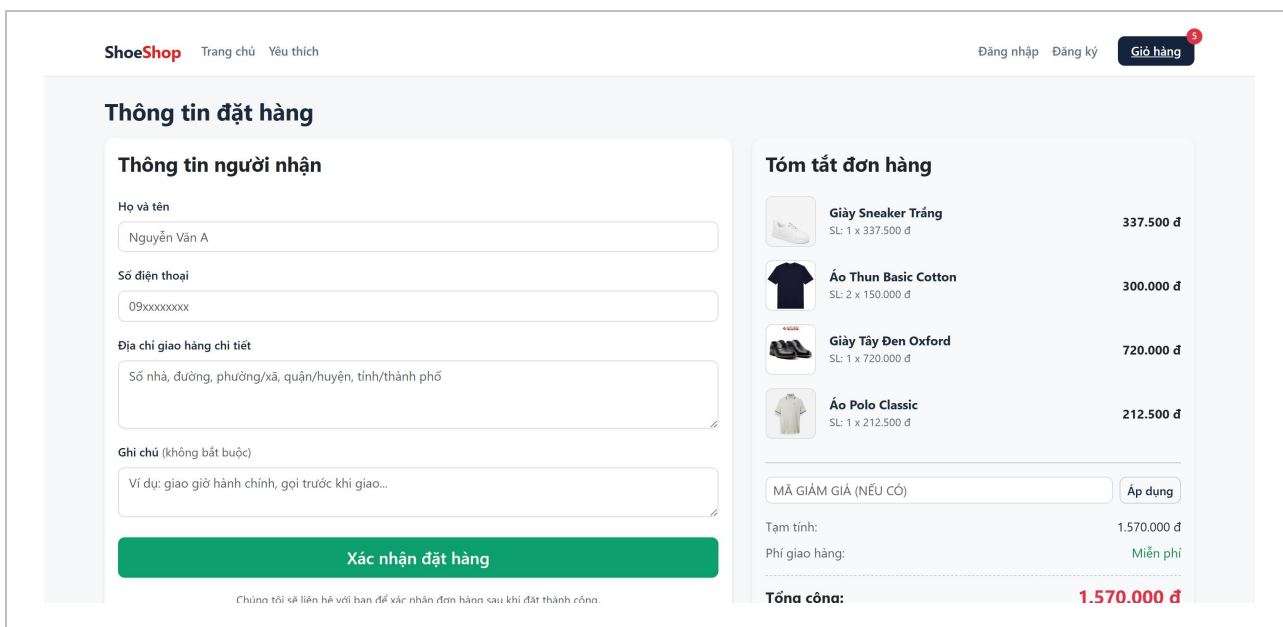
22



Hình 5.3: Trang giỏ hàng: cập nhật số lượng, đổi size, xóa và tính tổng tiền

5.4. Đặt hàng (Checkout)

Trang đặt hàng cho khách nhập họ tên, số điện thoại, địa chỉ, ghi chú và áp mã giảm giá. Hệ thống tính tạm tính – giảm giá – phí ship (miễn phí cho đơn từ 500.000đ) và hiển thị tổng cuối trước khi xác nhận.

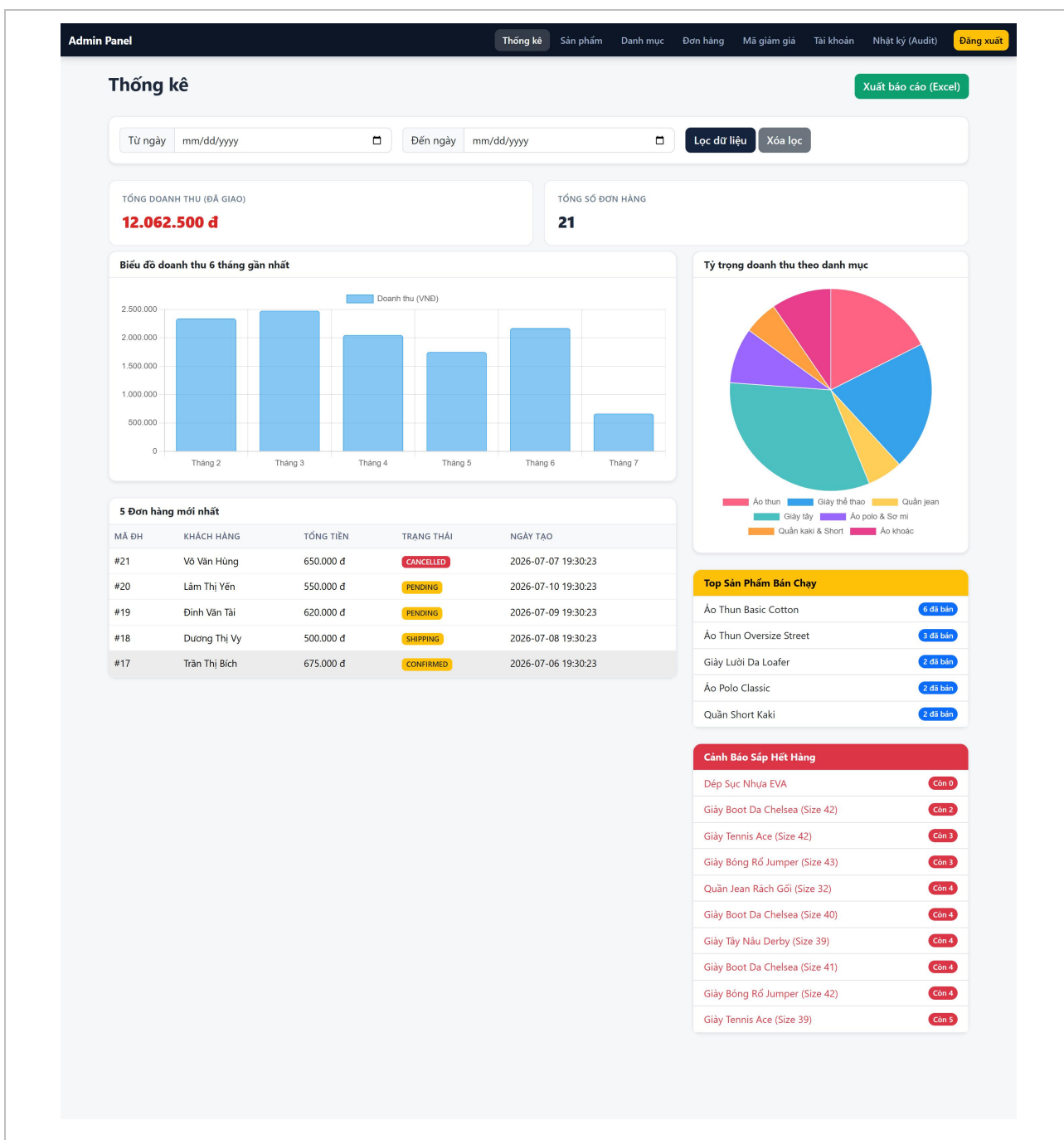


Hình 5.4: Trang đặt hàng: nhập thông tin, áp mã giảm giá và tính phí vận chuyển

5.5. Đăng nhập & Dashboard quản trị

Khu quản trị bắt đầu bằng trang đăng nhập bảo mật. Sau khi đăng nhập, dashboard hiển thị các thẻ số liệu (doanh thu, số đơn), biểu đồ doanh thu bằng Chart.js, top sản phẩm bán chạy và cảnh báo sắp hết hàng; có nút xuất báo cáo Excel.

Hình 5.5: Trang đăng nhập khu quản trị



Hình 5.6: Dashboard quản trị: thể số liệu, biểu đồ doanh thu và cảnh báo tồn kho

5.6. Quản lý sản phẩm (Admin)

Màn hình quản lý sản phẩm gồm danh sách có tìm kiếm và form thêm/sửa sản phẩm với upload ảnh, thiết lập giảm giá và quản lý phân loại (variant).

Admin Panel

Thống kê

Sản phẩm

Danh mục

Đơn hàng

Mã giảm giá

Tài khoản

Nhật ký (Audit)

Đăng xuất

Sửa sản phẩm

Quay lại danh sách

THÔNG TIN CƠ BẢN

Tên sản phẩm

Giày Sneaker Trắng

Danh mục

Giày thể thao

Giá (VNĐ)

450000

Số lượng

50

Giảm giá (%)

25

Giảm giá để 0 nếu không áp dụng. Tính cho cả giá gốc và giá phân loại.

Mô tả

Giày sneaker màu trắng năng động.

PHÂN LOẠI

Thêm phân loại

Để trống nếu sản phẩm không có phân loại. Mỗi loại có giá và tồn kho riêng.

TÊN LOẠI	GIÁ (VNĐ)	KHO
Size 39	450000	10
Size 40	450000	10

ÁNH SẢN PHẨM

giay sneake trang.jpg

Choose File

No file chosen

Chấp nhận .jpg, .png, gif — tối đa 5 MB. Bỏ trống để giữ ảnh cũ.

Lưu sản phẩm

Hủy

Hình 5.7: Form thêm/sửa sản phẩm với upload ảnh và quản lý phân loại

5.7. Quản lý đơn hàng (Admin)

Màn hình quản lý đơn hàng cho phép lọc theo trạng thái/SĐT/ngày, phân trang, xem chi tiết từng đơn và đổi trạng thái theo luật chuyển hợp lệ; mỗi lần đổi đều ghi vào lịch sử trạng thái.

Admin Panel

Thống kê

Sản phẩm

Danh mục

Đơn hàng

Mã giảm giá

Tài khoản

Nhật ký (Audit)

Đăng xuất

Quản lý đơn hàng

Tổng: 21 đơn

Trạng thái

— Tất cả —

▼

Số điện thoại

Nhập SĐT khách...

Từ ngày

mm/dd/yyyy

Đến ngày

mm/dd/yyyy

Lọc

Xóa lọc

ID	KHÁCH HÀNG	SĐT	NGÀY ĐẶT	TỔNG TIỀN	TRẠNG THÁI	
#21	Vô Văn Hùng	0903777888	2026-07-07 19:30:23	650.000 đ	Đã hủy	Xem chi tiết
#20	Lâm Thị Yến	0955444333	2026-07-10 19:30:23	550.000 đ	Chờ xử lý	Xem chi tiết
#19	Đinh Văn Tài	0966555444	2026-07-09 19:30:23	620.000 đ	Chờ xử lý	Xem chi tiết
#18	Dương Thị Vy	0977888999	2026-07-08 19:30:23	500.000 đ	Đang giao	Xem chi tiết
#17	Trần Thị Bích	0907654321	2026-07-06 19:30:23	675.000 đ	Đã xác nhận	Xem chi tiết
#16	Nguyễn Văn An	0901234567	2026-07-02 19:30:23	666.000 đ	Đã giao	Xem chi tiết
#15	Trương Văn Sơn	0911222333	2026-06-23 19:30:23	850.000 đ	Đã giao	Xem chi tiết
#14	Lý Thị Quỳnh	0922333444	2026-06-14 19:30:23	603.000 đ	Đã giao	Xem chi tiết
#13	Phan Văn Phú	0966777888	2026-06-03 19:30:23	720.000 đ	Đã giao	Xem chi tiết
#12	Mai Thị Ngọc	0955666777	2026-05-22 19:30:23	648.000 đ	Đã giao	Xem chi tiết

Hình 5.8: Danh sách và xử lý đơn hàng ở khu quản trị

CHƯƠNG 6. CÀI ĐẶT CHỨC NĂNG

Chương này mô tả cách cài đặt các chức năng tiêu biểu, minh họa bằng đoạn mã quan trọng và giải thích cách xử lý dữ liệu bằng Servlet/JDBC. Các biện pháp bảo mật và kiểm thử được trình bày ở mục 6.12 và 6.13.

6.1. Trang chủ: duyệt, lọc, tìm kiếm, phân trang

HomeServlet đọc các tham số categoryId, minPrice, maxPrice, keyword, sort, page từ URL. Nếu không có bộ lọc nào, Servlet phân trang trực tiếp ở tầng CSDL (6 sản phẩm/trang); nếu có lọc, nó gọi ProductDAO.filter(...) rồi phân trang trong bộ nhớ. Tìm kiếm gợi ý do SearchApiServlet xử lý: khi gõ ≥ 2 ký tự, JavaScript gọi /api/search và nhận về tối đa 5 gợi ý dạng JSON.

6.2. Chi tiết sản phẩm: gallery, phân loại, đánh giá

Trang chi tiết hiển thị thư viện ảnh (bảng product_images), danh sách phân loại (mỗi loại có giá và tồn kho riêng), phần trăm giảm giá và sản phẩm liên quan. Khách đã mua (xác thực qua SĐT) có thể gửi đánh giá 1–5 sao. ReviewApiServlet kiểm tra điều kiện “đã mua” trước khi lưu:

```
// ReviewApiServlet: chỉ cho đánh giá nếu SĐT này đã từng mua sản phẩm
if (!reviewDAO.hasPurchased(phone, productId)) {
    resp.getWriter().write("{\"success\":false,\"message\":\""
        + "\"So dien thoai nay chua tung mua san pham...\"}");
    return;
}
Review r = new Review();
r.setProductId(productId); r.setPhone(phone);
r.setRating(rating);      r.setComment(comment);
reviewDAO.insert(r);
```

Mã 6.1: Kiểm tra điều kiện đã mua trước khi cho đánh giá

6.3. Giỏ hàng lưu bằng Cookie

Điểm đặc trưng của dự án là giỏ hàng không dùng bảng CSDL mà lưu trong Cookie tên “cart”, giúp cả khách chưa đăng nhập vẫn mua được. Mỗi dòng giỏ có định dạng productId:variantId:quantity, các dòng cách nhau bằng dấu phẩy và toàn bộ được URL-encode. Khóa gộp dòng là cặp (productId, variantId). Cookie chỉ lưu id và số lượng; tên, giá và ảnh được đọc lại từ CSDL mỗi lần hiển thị nhằm chống việc client sửa giá.

```
// CartServlet: lưu giỏ vào Cookie 7 ngày (giá trị được URL-encode)
private void saveCookie(HttpServletResponse resp, List<String> items) {
    String raw = String.join(",", items);           // "1:2:3,14:44:2"
    Cookie c = new Cookie("cart", URLEncoder.encode(raw, "UTF-8"));
    c.setMaxAge(60 * 60 * 24 * 7);                 // 7 ngày
    c.setPath("/");
    resp.addCookie(c);
}
```

Mã 6.2: Ghi giỏ hàng vào Cookie

6.4. Thêm giỏ bằng AJAX và badge số lượng

CartApiServlet (/api/cart/add) nhận request AJAX, kiểm tra tồn kho, cập nhật Cookie và trả về JSON chứa tổng số món trong giỏ. Nhờ đó nút “Thêm vào giỏ” hoạt động không tải lại trang: badge trên navbar cập nhật tức thì và hiển thị thông báo Toast.

6.5. Đặt hàng (Checkout): validate, coupon, phí ship

CheckoutServlet đảm nhiệm luồng đặt hàng. Toàn bộ dữ liệu được validate phía server (không tin form HTML): họ tên 2–150 ký tự, số điện thoại khớp mẫu di động Việt Nam, địa chỉ 5–255 ký tự. Số tiền được tính lại tại máy chủ với giá đọc từ CSDL; phí ship 30.000đ và miễn phí cho đơn từ 500.000đ; mã giảm giá được kiểm tra lại mỗi lần tính để phòng trường hợp vừa hết hạn/hết lượt.

```
// CheckoutServlet: validate phía server
if (!phone.matches(PHONE_PATTERN)) {           // ^0[35789]\d{8}$
    errors.add("Số điện thoại không hợp lệ (10 số, bắt đầu 03/05/07/08/09).");
}
...
// Phí ship: miễn phí cho đơn từ 500.000đ
t.shipFee = t.subtotal.compareTo(FREE_SHIP_THRESHOLD) >= 0
    ? BigDecimal.ZERO : SHIP_FEE;              // SHIP_FEE = 30.000
t.grandTotal = t.subtotal.subtract(t.discount).add(t.shipFee);
```

Mã 6.3: Kiểm tra dữ liệu và tính tiền phía máy chủ

6.6. Xử lý đơn hàng bằng Transaction

OrderDAO.createOrder() gói toàn bộ nghiệp vụ tạo đơn trong một giao dịch (transaction): trừ tồn kho từng món, trừ lượt sử dụng coupon, chèn bản ghi đơn, chèn các dòng chi tiết và ghi lịch sử trạng thái. Nếu bất kỳ bước nào lỗi (ví dụ một món vừa hết hàng), toàn bộ giao dịch được rollback. Điều kiện “quantity >= ?” đặt ngay trong câu UPDATE nên hai người đặt cùng lúc cũng không thể làm tồn kho âm.

```

conn.setAutoCommit(false); // BẮT ĐẦU TRANSACTION
for (OrderItem item : order.getItems()) // 1) trừ tồn kho từng món
    deductStock(conn, item);
// 2) trừ lượt coupon (kiểm tra hạn & lượt ngay trong UPDATE)
// 3) INSERT orders → lấy id → INSERT order_items (batch)
// 4) INSERT order_status_history (bản ghi tạo đơn)
conn.commit(); // THÀNH CÔNG

// deductStock: điều kiện đủ hàng nằm trong chính câu UPDATE
"UPDATE product_variants SET quantity = quantity - ? "
+ "WHERE id = ? AND quantity >= ?";
if (ps.executeUpdate() == 0) // 0 dòng bị đổi = không đủ hàng
    throw new OrderException(outOfStockMessage(item));

```

Mã 6.4: Tạo đơn hàng trong transaction, trừ tồn kho an toàn

6.7. Vòng đời & trạng thái đơn hàng

Trạng thái đơn tuân theo một máy trạng thái có luật chuyển hợp lệ (OrderStatus.canTransition). Khi admin hủy đơn, hệ thống tự hoàn lại tồn kho cho các món trong đơn. Mọi lần đổi trạng thái đều được ghi vào order_status_history (ai đổi, từ trạng thái nào sang trạng thái nào, lúc nào).



Hình 6.1: Máy trạng thái vòng đời đơn hàng

Trạng thái	Ý nghĩa	Có thể chuyển sang
PENDING	Chờ xác nhận (vừa đặt)	CONFIRMED, CANCELLED
CONFIRMED	Đã xác nhận	SHIPPING, CANCELLED
SHIPPING	Đang giao	DELIVERED, CANCELLED
DELIVERED	Đã giao (tính doanh thu)	— (kết thúc)
CANCELLED	Đã hủy (hoàn tồn kho)	— (kết thúc)

6.8. Hệ thống tài khoản khách hàng

RegisterServlet xử lý đăng ký với validate (mật khẩu ≥ 6 ký tự, xác nhận khớp, username chưa tồn tại); mật khẩu được băm BCrypt trước khi lưu. AccountServlet cho phép khách xem/sửa hồ sơ và xem lịch sử đơn hàng của mình (truy vấn theo user_id). Chức năng “ghi nhớ đăng nhập” dùng cookie token 30 ngày, được RememberMeFilter tự động khôi phục phiên.

6.9. Quản lý sản phẩm & upload ảnh (Admin)

AdminProductServlet dùng @MultipartConfig để nhận file ảnh (giới hạn 5 MB/ảnh, 10 MB/request). Ảnh được đặt tên theo timestamp để tránh trùng, ghi vào thư mục assets/images của ứng dụng; khi đổi ảnh hoặc xóa sản phẩm, file ảnh cũ cũng được dọn dẹp. Servlet còn validate phía server, quản lý phân loại (variants) và ghi nhật ký hoạt động sau mỗi thao tác Thêm/Sửa/Xóa.

```
@MultipartConfig(fileSizeThreshold = 1*1024*1024,
                  maxFileSize = 5*1024*1024, maxRequestSize = 10*1024*1024)
...
Part imagePart = req.getPart("imageFile");
if (imagePart != null && imagePart.getSize() > 0) {
    String fileName = System.currentTimeMillis() + ext; // tránh trùng tên
    String uploadDir = getServletContext().getRealPath("/assets/images/");
    new File(uploadDir).mkdirs();
    imagePart.write(uploadDir + File.separator + fileName);
    image = fileName;
}
ActivityLogDAO.log(admin.getUsername(), "CREATE", "PRODUCT", p.getId(), ...);
```

Mã 6.5: Upload ảnh sản phẩm và ghi nhật ký

6.10. Thống kê (Dashboard) & xuất Excel

DashboardServlet tổng hợp số liệu từ DashboardDAO: tổng doanh thu (chỉ tính đơn DELIVERED), số đơn, biểu đồ doanh thu 6 tháng gần nhất (biểu đồ cột), tỷ trọng doanh thu theo danh mục (biểu đồ tròn), top 5 sản phẩm bán chạy và cảnh báo các phân loại sắp hết hàng. Dữ liệu được nhúng vào biểu đồ Chart.js; tên danh mục được escape trước khi nhúng vào mảng JavaScript để chống XSS. Ngoài ra, DashboardServlet.exportToExcel dùng Apache POI (XSSFWorkbook) để xuất báo cáo doanh thu ra file revenue_report.xlsx cho quản trị viên tải về.

```
// DashboardServlet: xuất báo cáo doanh thu ra Excel bằng Apache POI
XSSFWorkbook wb = new XSSFWorkbook();
```

```

Sheet sheet = wb.createSheet("Doanh thu");
// ... đổ dữ liệu doanh thu theo tháng vào từng dòng ...
resp.setContentType("application/vnd.openxmlformats-officedocument.spreadsheetml.sheet");
resp.setHeader("Content-Disposition", "attachment; filename=revenue_report.xlsx");
wb.write(resp.getOutputStream());
wb.close();

```

Mã 6.6: Xuất báo cáo doanh thu ra file Excel (.xlsx)

6.11. Nhật ký hoạt động (Audit Log)

Mọi thao tác Thêm/Sửa/Xóa của quản trị viên trên sản phẩm, danh mục, coupon... đều được ghi vào bảng activity_logs qua ActivityLogDAO.log(username, action, entity, entityId, description). Trang /admin/logs cho phép admin tra cứu lại lịch sử này, phục vụ kiểm soát và truy vết.

6.12. Bảo mật hệ thống

6.12.1. Chống SQL Injection

Toàn bộ truy vấn tới CSDL đều dùng PreparedStatement với tham số hóa (dấu ?), không nối chuỗi trực tiếp từ dữ liệu người dùng — biện pháp căn bản và hiệu quả nhất chống SQL Injection.

6.12.2. Mã hóa mật khẩu & chống dò mật khẩu

Mật khẩu không bao giờ lưu plain-text: khi đăng ký được băm bằng jBCrypt, khi đăng nhập dùng BCrypt.checkpw để so khớp. LoginServlet đếm số lần sai; sau 5 lần sai liên tiếp, tài khoản bị khóa tạm 15 phút; đăng nhập đúng thì đặt lại biến đếm về 0.

```

private static final int MAX_FAILED_ATTEMPTS = 5;
private static final long LOCK_TIME_DURATION = 15 * 60 * 1000; // 15 phút

if (BCrypt.checkpw(password, user.getPassword())) {
    userDAO.updateFailedAttempts(username, 0, null); // đăng nhập đúng → reset
    req.getSession().setAttribute("loggedInUser", user);
} else {
    int attempts = user.getFailedAttempts() + 1; // sai → tăng đếm
    Timestamp lockTime = (attempts >= MAX_FAILED_ATTEMPTS)
        ? new Timestamp(System.currentTimeMillis()) : null;
    userDAO.updateFailedAttempts(username, attempts, lockTime);
}

```

Mã 6.7: BCrypt và cơ chế khóa tài khoản khi sai nhiều lần

6.12.3. Phân quyền theo vai trò (Filter)

AuthFilter chặn mọi truy cập vào /admin/*. Chưa đăng nhập → chuyển về login; là CUSTOMER → lỗi 403. STAFF chỉ được xử lý đơn hàng, xem dashboard và đổi mật khẩu; bị chặn sản phẩm, danh mục, coupon, người dùng và nhật ký. Chỉ ADMIN mới toàn quyền.

```
// AuthFilter: STAFF bị giới hạn phạm vi trong khu /admin/*
if ("STAFF".equals(role)) {
    if (path.startsWith("/admin/products") ||
        path.startsWith("/admin/categories") ||
        path.startsWith("/admin/coupons") ||
        path.startsWith("/admin/users") ||
        path.startsWith("/admin/logs")) {
        resp.sendError(HttpServletResponse.SC_FORBIDDEN,
            "Nhân viên không có quyền truy cập chức năng này.");
        return;
    }
}
```

Mã 6.8: Phân quyền STAFF trong AuthFilter

6.12.4. Các biện pháp bổ sung

- **Ấn View:** JSP đặt trong WEB-INF/views nên không thể truy cập trực tiếp qua URL — buộc đi qua Servlet.
- **Validate phía server:** Validate toàn bộ dữ liệu ở máy chủ (tên, SĐT, địa chỉ, giá, số lượng) thay vì tin form phía client.
- **Chống sửa giá:** Giá được đọc lại từ CSDL khi hiển thị giỏ và khi tính tiền, chống việc sửa giá qua Cookie.
- **Chống XSS:** Escape dữ liệu (tên danh mục) trước khi nhúng vào mảng JavaScript trên dashboard.
- **Mã hóa ký tự:** EncodingFilter ép UTF-8 cho request để dữ liệu tiếng Việt không bị lỗi font.
- **Trang lỗi thân thiện:** Cấu hình trang lỗi tùy chỉnh cho mã 404/500/403 trong web.xml, tránh lộ thông tin hệ thống.

6.13. Kiểm thử

Nhóm áp dụng kiểm thử thủ công theo kịch bản (manual testing) trên trình duyệt, tập trung vào các luồng nghiệp vụ chính và trường hợp biên (dữ liệu sai, hết hàng, mã giảm

giá hết hạn, phân quyền). Mỗi thành viên tự kiểm thử phần mình trước khi tích hợp vào nhánh chính.

Mã	Cá kiểm thử	Kết quả mong đợi	KQ
TC-01	Lọc sản phẩm theo danh mục + khoảng giá	Trả về đúng sản phẩm, phân trang đúng	Đạt
TC-02	Tìm kiếm gợi ý với từ khóa < 2 ký tự	Không trả về gợi ý	Đạt
TC-03	Thêm vào giỏ vượt tồn kho	Bị chặn, báo lỗi hết hàng	Đạt
TC-04	Thêm giỏ bằng AJAX	Badge cập nhật, không tải lại trang	Đạt
TC-05	Đặt hàng với SĐT sai định dạng	Báo lỗi, giữ lại dữ liệu đã nhập	Đạt
TC-06	Đặt hàng đơn $\geq 500.000đ$	Miễn phí vận chuyển	Đạt
TC-07	Áp mã giảm giá hết hạn	Từ chối mã, thông báo rõ ràng	Đạt
TC-08	Đặt hàng khi một món vừa hết hàng	Rollback toàn bộ, không tạo đơn	Đạt
TC-09	Hủy đơn hàng	Trạng thái CANCELLED, hoàn lại tồn kho	Đạt
TC-10	Đăng nhập sai 5 lần	Khóa tài khoản tạm 15 phút	Đạt
TC-11	STAFF truy cập /admin/products	Trả lỗi 403 Forbidden	Đạt
TC-12	Khách chưa mua gửi đánh giá	Bị từ chối	Đạt
TC-13	Xuất báo cáo Excel từ dashboard	Tải về file revenue_report.xlsx	Đạt
TC-14	Ghi nhớ đăng nhập (remember me)	Phiên tự khôi phục từ cookie	Đạt
TC-15	Truy cập trực tiếp /WEB-INF/views/home.jsp	Không truy cập được	Đạt

CHƯƠNG 7. PHÂN CÔNG CÔNG VIỆC NHÓM

Nhóm gồm 4 thành viên, mỗi người phụ trách một mảng độc lập theo nguyên tắc “code phần nào — viết tài liệu phần đó — thuyết trình phần đó”, làm việc trên nhánh Git riêng và tích hợp qua Pull Request.

Thành viên	Vai trò	Mảng phụ trách	Sở hữu dữ liệu chính
Trần Tuấn Anh (Nhóm trưởng)	Điều phối + Khách hàng	Duyệt/ lọc/tìm sản phẩm, giỏ hàng (Cookie), AJAX, wishlist, quick-view, đánh giá	Giỏ hàng (Cookie), reviews, wishlists
Hồ Huy Hoàng	Nền tảng + Sản phẩm	Khung dự án MVC, layout dùng chung, CRUD sản phẩm, upload ảnh, phân loại	Bảng products, product_variants
Nguyễn Hoàng Anh Khoa	Đơn hàng	Checkout, transaction đặt hàng, trừ/hoàn tiền kho, quản lý đơn của admin	Bảng orders, order_items, coupons
Trần Trung Nguyên	Bảo mật + Thống kê	Đăng nhập BCrypt, phân quyền, danh mục, dashboard & biểu đồ, xuất Excel, nhật ký	Bảng users, categories, activity_logs

7.1. Mức độ đóng góp

Thành viên	Mức độ đóng góp	Ghi chú
Trần Tuấn Anh	25%	Nhóm trưởng, điều phối + phần khách hàng
Hồ Huy Hoàng	25%	Nền tảng dự án + quản lý sản phẩm
Nguyễn Hoàng Anh Khoa	25%	Vòng đời đơn hàng
Trần Trung Nguyên	25%	Bảo mật, danh mục, thống kê

7.2. Quy trình Git

Mỗi thành viên phát triển trên nhánh riêng (Anh / Hoàng / Khoa / Nguyên), thường xuyên git pull origin main để đồng bộ, sau đó tạo Pull Request vào nhánh main để cả nhóm review trước khi merge. Cách làm này giúp hạn chế xung đột và giữ nhánh main luôn ở trạng thái chạy được.

7.3. Thống kê mã nguồn

Hạng mục	Số lượng
Lớp Java (model/dao/controller/filter/util)	khoảng 50 lớp
Servlet	21
DAO	11
Model	13
Trang JSP	27
Bảng cơ sở dữ liệu	12

CHƯƠNG 8. KẾT QUẢ ĐẠT ĐƯỢC

8.1. Các chức năng đã hoàn thành

Nhóm đã xây dựng hoàn chỉnh một website thương mại điện tử bán quần áo – giày dép chạy được end-to-end, đúng mô hình MVC với khoảng 50 lớp Java, 27 trang JSP và 12 bảng dữ liệu:

- Phía khách hàng: duyệt/lọc/tìm kiếm gợi ý, chi tiết sản phẩm với gallery và phân loại, giỏ hàng Cookie, thêm giỏ AJAX, đặt hàng có mã giảm giá và phí ship, tài khoản khách hàng, wishlist, quick-view, đánh giá.
- Phía quản trị: đăng nhập bảo mật, quản lý sản phẩm (upload ảnh, phân loại), danh mục, đơn hàng (máy trạng thái + lịch sử), mã giảm giá, người dùng, thống kê bằng biểu đồ, xuất Excel và nhật ký hoạt động.

8.2. Những điểm nổi bật của sản phẩm

- Đầy đủ CRUD trên nhiều đối tượng (sản phẩm, danh mục, mã giảm giá) và hơn 6 tính năng chính.
- Transaction đảm bảo toàn vẹn tồn kho khi đặt hàng; điều kiện đủ hàng nằm ngay trong câu UPDATE.
- Bảo mật tốt: BCrypt, chống brute-force, phân quyền 3 vai trò, chống SQL Injection và XSS.
- Chạy được ngay không cần cài Tomcat nhờ plugin Cargo; có dữ liệu mẫu phong phú để chấm/demo.

8.3. Những hạn chế còn tồn tại

- Chưa tích hợp cổng thanh toán trực tuyến (mô hình đặt hàng liên hệ/COD).
- Ảnh sản phẩm lưu trong thư mục triển khai nên sẽ mất khi chạy lại mvn clean (chấp nhận được với đồ án demo).
- Chưa có kiểm thử tự động (unit/integration test); mới kiểm thử thủ công theo kịch bản.
- Giỏ hàng Cookie giới hạn dung lượng và không đồng bộ giữa các thiết bị.

CHƯƠNG 9. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

9.1. Kết luận

Qua đồ án, nhóm đã vận dụng và củng cố kiến thức lập trình web phía máy chủ: mô hình MVC, Servlet/JSP, JDBC/MySQL, quản lý phiên, bảo mật và làm việc nhóm bằng Git. Sản phẩm là một website bán hàng hoàn chỉnh, chạy được thực tế, đáp ứng đầy đủ yêu cầu của đề (frontend, backend, database, CRUD và trên 4 tính năng chính). Đây là nền tảng quan trọng để nhóm tiếp tục phát triển các ứng dụng web phức tạp hơn.

9.2. Hướng phát triển

- Tích hợp cổng thanh toán (VNPay/Momo) và theo dõi vận chuyển.
- Đồng bộ giỏ hàng theo tài khoản đăng nhập (lưu CSDL) để dùng đa thiết bị.
- Bổ sung kiểm thử tự động và tích hợp CI để tăng độ tin cậy.
- Lưu ảnh lên dịch vụ lưu trữ ngoài (cloud storage) và tối ưu tốc độ tải.
- Mở rộng thống kê nâng cao và gợi ý sản phẩm cá nhân hóa.

CHƯƠNG 10. TÀI LIỆU THAM KHẢO

- [1] Oracle, Java Servlet & JavaServer Pages (JSP) Documentation, docs.oracle.com.
- [2] The Apache Software Foundation, Apache Tomcat 9 Documentation, tomcat.apache.org.
- [3] MySQL, MySQL 8.0 Reference Manual & Connector/J, dev.mysql.com.
- [4] Bootstrap, Bootstrap 5 Documentation, getbootstrap.com.
- [5] Chart.js, Chart.js Documentation, chartjs.org.
- [6] The Apache Software Foundation, Apache POI – Java API for Microsoft Documents, poi.apache.org.
- [7] D. Mazières, jBCrypt – A Java BCrypt implementation, mindrot.org/projects/jBCrypt.
- [8] Apache Maven Project & Codehaus Cargo Plugin, maven.apache.org, codehaus-cargo.github.io.

CHƯƠNG Phụ lục. HƯỚNG DẪN CÀI ĐẶT VÀ CHẠY

Yêu cầu môi trường: JDK 11 trở lên, Apache Maven 3.6+, MySQL 8 đang chạy. Không cần cài Tomcat — plugin Cargo sẽ tự tải Tomcat 9 khi chạy lần đầu.

1. Tạo cơ sở dữ liệu: chạy script database/database.sql (lệnh: `mysql -u root -p < database/database.sql`).
2. Cấu hình kết nối: mở `web/src/main/java/com/shop/util/DBConnection.java`, sửa USER và PASSWORD cho khớp MySQL.
3. Chạy ứng dụng: mở terminal trong thư mục web/, gõ: `mvn clean package cargo:run` (lần đầu sẽ tải Tomcat + thư viện).
4. Truy cập: trang khách `http://localhost:8081/shop/home` ; trang quản trị `http://localhost:8081/shop/admin/login` (admin / 123456).